TECHNICAL DETAIL

Title	Broken Access Control Unauthorized Access to Hidden Profile Management Page
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/profile
Severity	Low
CVSS Score	3.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan kontrol akses di mana halaman profil pengguna (/profile) tetap aktif dan dapat diakses secara langsung melalui URL, meskipun fitur tersebut sengaja disembunyikan atau tidak disediakan pada antarmuka pengguna (UI) utama. Melalui pemindaian direktori, teridentifikasi bahwa rute ini tidak dinonaktifkan di sisi server, sehingga memungkinkan pengguna yang telah masuk untuk melakukan tindakan sensitif yang berada di luar prosedur resmi aplikasi. Hal ini mencakup kemampuan untuk mengubah informasi profil, memperbarui kata sandi, hingga melakukan penghapusan akun secara mandiri.

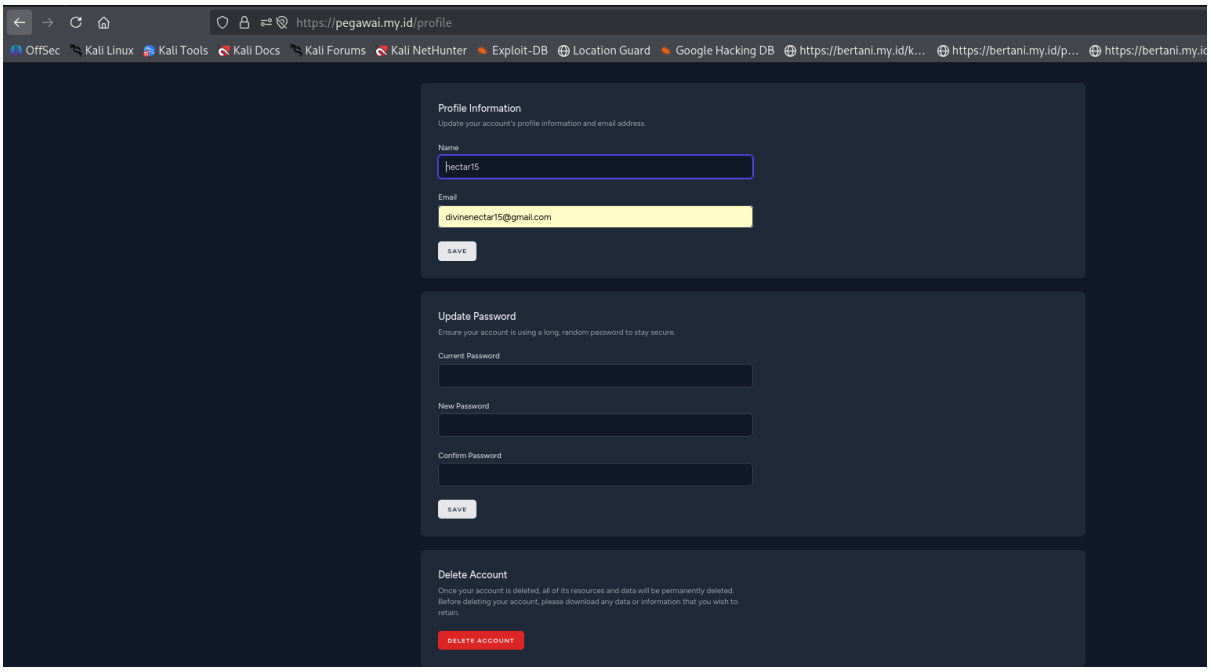
STEPS TO REPRODUCE

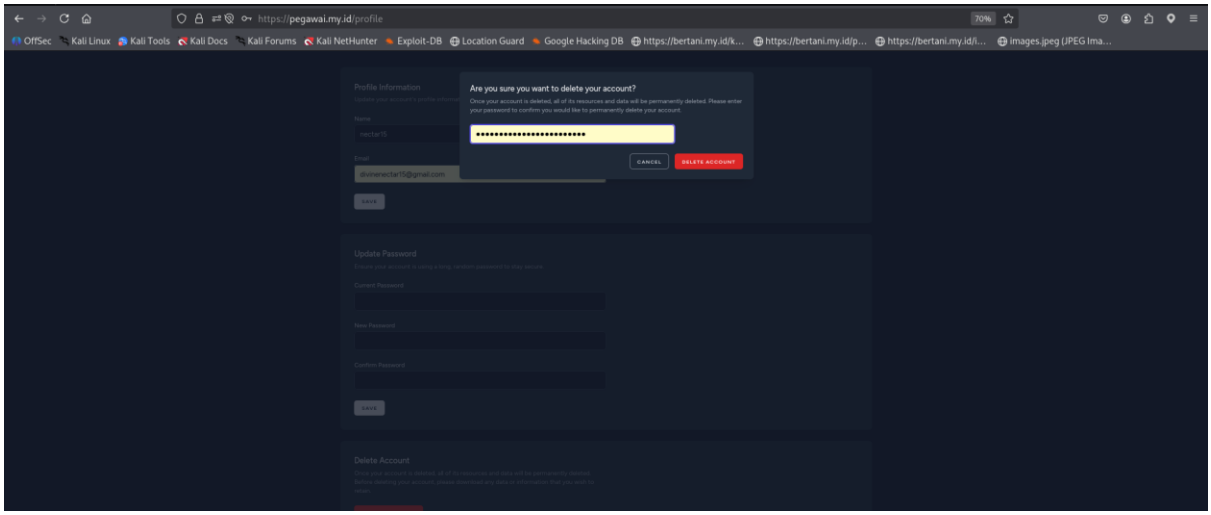
1. gobuster dir -u https://pegawai.my.id -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -s "200,204,301,302,307,403" -b ""

```
zsh: corrupt history file /home/nectar/.zsh_history
┌──(nectar㉿nectar)-[~]
└─$ gobuster dir -u https://pegawai.my.id -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -s "200,204,301,302,307,403" -b ""
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:            https://pegawai.my.id
[+] Method:         GET
[+] Threads:        10
[+] Wordlist:       /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Status codes:   301,302,307,403,200,204
[+] User Agent:     gobuster/3.8
[+] Timeout:        10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/login               (Status: 200) [Size: 4060]
/register            (Status: 200) [Size: 4574]
/profile             (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
```

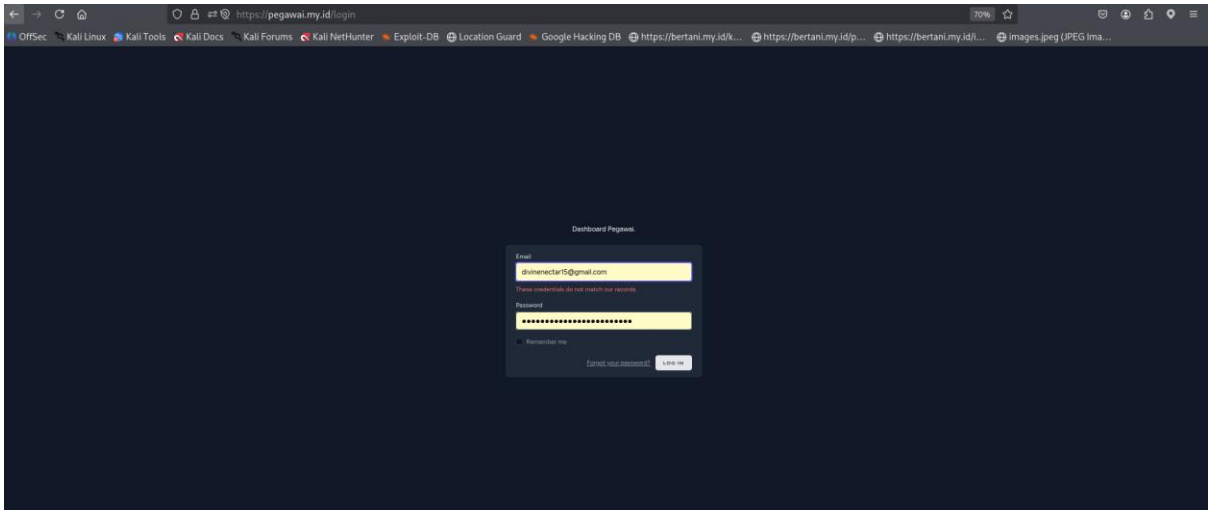
2. Dari informasi tersebut terdapat url /profile yang dimana tidak bisa kita akses di halaman web karena web tidak menyediakan fitur yang mengarahkan ke profile

3. Login ke akun Anda
4. Tampilan saat masuk ke url https://pegawai.my.id/profile disini kita dapat ganti nama email ,password dan hapus akun . Disini saya coba hapus akun





5. Bukti akun berhasil terhapus



EXPECTED RESULT

1. Rute yang tidak digunakan atau tidak dimaksudkan untuk diakses oleh pengguna seharusnya dinonaktifkan sepenuhnya di sisi server atau dilindungi dengan izin akses yang sangat ketat.
2. Pengguna yang mencoba mengakses /profile seharusnya menerima respons HTTP 404 *Not Found* atau 403 *Forbidden* jika fitur tersebut memang tidak diizinkan oleh kebijakan bisnis perusahaan

ACTUAL RESULT

1. Pengguna yang sudah login dapat mengakses halaman profil secara penuh dan menjalankan fungsi pembaruan data serta penghapusan akun meskipun tombol aksesnya tidak tersedia di dasbor utama.
2. Server tetap memproses permintaan pengubahan data dan penghapusan akun dari *endpoint* ini tanpa adanya validasi tambahan apakah fitur ini seharusnya aktif atau tidak.

IMPACT

1. Pelanggaran Kebijakan Bisnis: Pengguna dapat memodifikasi data atau menghapus akun mereka di luar prosedur resmi yang ditetapkan oleh organisasi, yang mungkin memerlukan persetujuan administrasi.
2. Risiko Integritas Data: Memungkinkan adanya inkonsistensi data jika akun karyawan dihapus secara sepihak tanpa sepengetahuan pihak administrasi atau HR, yang dapat mengganggu audit internal.

RECOMMENDATION

1. Nonaktifkan Rute: Jika fitur profil memang tidak diperlukan dalam proses bisnis saat ini, hapus atau komentari rute terkait di berkas konfigurasi *routing* aplikasi (seperti web.php).
2. Otorisasi Sisi Server: Jika fitur ini akan digunakan di masa depan, pastikan akses dikontrol melalui kebijakan otoritas yang jelas dan terdokumentasi di sisi server, bukan sekadar menyembunyikan elemen di antarmuka.

REFERENCES

1. **OWASP Top 10 - A01:2021 Broken Access Control**: https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-284: Improper Access Control**: https://cwe.mitre.org/data/definitions/284.html